

NETWORKING CORE PROTOCOLS

[Kaynak](#)

İÇERİK

1. DNS: Adresleri Hatırlamak (Remembering Addresses)
2. WHOIS: Alan Adının Sahibi Kim?
3. HTTP(S): Web Dünyasına Giriş
4. FTP: Dosya Transfer Protokolü (Transferring Files)
5. SMTP: E-posta Gönderme Protokolü (Sending Email)
6. POP3: E-postaları Almak (Receiving Email)
7. IMAP: E-postaları Senkronize Etmek (Synchronizing Email)
8. Özet ve Protokol Port Bilgisi (Conclusion)

DNS: Adresleri Hatırlamak (Remembering Addresses)

İnternet dünyasında cihazlar birbirleriyle IP adresleri üzerinden haberleşir. Ancak biz insanlar için karmaşık rakam gruplarını akılda tutmak imkansıza yakındır. İşte bu noktada devreye **DNS** (Domain Name System - Alan Adı Sistemi) giriyor. DNS, temel olarak "alan adlarını" (domain name) makinelerin anlayabileceği "IP adreslerine" eşleyen devasa bir telefon defteri gibidir.

DNS'in Teknik Altyapısı ve Çalışma Mantığı

DNS, sadece bir isim çözme servisi değil, ağ hiyerarşisinin temel taşıdır. Teknik olarak şu özellikleri bilmemiz şart:

- **OSI Katmanı:** DNS, **Application Layer** (Uygulama Katmanı - Katman 7) protokolüdür.
- **Port ve Protokol:** Varsayılan olarak **UDP 53** portunu kullanır. Ancak veri boyutu UDP paket sınırlarını aşarsa veya bölge transferi (Zone Transfer) gibi işlemler yapılacaksa **TCP 53** portuna geri döner (fallback).
- **Hız ve Verimlilik:** Sorguların çoğu küçük paketlerden oluştuğu için hız amacıyla UDP tercih edilir.

Temel DNS Kayıt Türleri

Bir siber güvenlik uzmanı veya ağ yöneticisi olarak karşımıza en çok çıkacak dört temel kayıt türü şunlardır:

1. A Kaydı (Address Record)

Bir ana bilgisayar adını (hostname) doğrudan bir veya birden fazla **IPv4** adresine eşler. Tarayıcıya bir site adı yazdığımızda ilk sorgulanan kayıttır.

Örnek: `example.com -> 172.17.2.172`

2. AAAA Kaydı (Quad-A Record)

A kaydı ile aynı mantıkta çalışır ancak **IPv6** adresleri içindir. İsmindeki "AAAA", IPv6 adreslerinin IPv4'ten dört kat daha uzun (128-bit vs 32-bit) olmasından gelir. *Not: AAA (üç A) ile karıştırmayın, o Kimlik Doğrulama (Authentication, Authorization, Accounting) anlamına gelir ve DNS ile ilgisi yoktur.*

3. CNAME Kaydı (Canonical Name Record)

Bir alan adını başka bir alan adına yönlendirir. Takma ad (alias) oluşturmak için kullanılır.

Örnek: `www.example.com` adresini `example.com` adresine yönlendirebilirsiniz. Bu sayede IP adresi değiştiğinde sadece ana kaydı güncellemek yeterli olur.

4. MX Kaydı (Mail Exchange Record)

İlgili alan adı için e-posta trafiğini hangi sunucunun yöneteceğini belirtir. Birine e-posta gönderdiğinizde, gönderen sunucu karşı tarafın MX kaydına bakarak e-postayı nereye teslim edeceğini anlar.

Komut Satırı Üzerinden DNS Sorgulama: nslookup

Bir alan adının arkasındaki IP adresini öğrenmek için en temel araç **nslookup** aracıdır.

Bash

```
user@TryHackMe$ nslookup www.example.com
Server:      127.0.0.53
Address:     127.0.0.53#53

Non-authoritative answer:
Name:   www.example.com
Address: 93.184.215.14
Name:   www.example.com
Address: 2606:2800:21f:cb07:6820:80da:af6b:8b2c
```

Çıktı Analizi:

- Server/Address:** Sorgunun hangi yerel DNS çözücüyü (resolver) sorulduğunu gösterir. Burada `127.0.0.53` yerel bir ara yüzdür.
- Non-authoritative answer (Yetkili olmayan cevap):** Bu cevap, bilgiyi doğrudan alan adının kendi sunucusundan değil, bir ara sunucunun (cache) ön belleğinden aldığımızı belirtir.

- **Address:** Hem IPv4 (A kaydı) hem de IPv6 (AAAA kaydı) sonuçları döndürülmüştür.

DNS Trafiğinin Paket Seviyesinde İncelenmesi

Bir DNS sorgusu yapıldığında arka planda neler olup bittiğini anlamak için **tshark** (Wireshark'ın komut satırı versiyonu) çıktılarına bakabiliriz.

Bash

```
user@TryHackMe$ tshark -r dns-query.pcapng -Nn
1 0.0000000000 192.168.66.89 → 192.168.66.1 DNS 86 Standard query 0x2e0f
A www.example.com OPT
2 0.059049584 192.168.66.1 → 192.168.66.89 DNS 102 Standard query
response 0x2e0f A www.example.com A 93.184.215.14 OPT
3 0.059721705 192.168.66.89 → 192.168.66.1 DNS 86 Standard query 0x96e1
AAAA www.example.com OPT
4 0.101568276 192.168.66.1 → 192.168.66.89 DNS 114 Standard query
response 0x96e1 AAAA www.example.com AAAA
2606:2800:21f:cb07:6820:80da:af6b:8b2c OPT
```

Trafik Analizi ve Parametreler:

- **-r dns-query.pcapng:** Belirtilen pcap dosyasını oku.
- **-Nn:** İsim çözümlemesini devre dışı bırak (IP'leri olduğu gibi göster).

Adım Adım Akış:

1. **Paket 1:** İstemci (192.168.66.89), DNS sunucusuna (192.168.66.1) bir **A kaydı** sorgusu gönderiyor (ID: 0x2e0f).
2. **Paket 2:** Sunucu, bu sorguya cevap veriyor ve 93.184.215.14 IP adresini döndürüyor.
3. **Paket 3:** İstemci bu sefer aynı alan adı için bir **AAAA kaydı** sorgusu (IPv6) başlatıyor (ID: 0x96e1).
4. **Paket 4:** Sunucu, IPv6 adresini içeren cevabı döndürerek işlemi tamamlıyor.

Unutma: Tek bir `nslookup` komutu aslında arka planda hem IPv4 hem IPv6 için ayrı ayrı sorgular üretir. Bu yüzden trafik analizinde çift paket (sorgu-yanıt) görmemiz normaldir.

WHOIS: Alan Adının Sahibi Kim?

Bir önceki bölümde bir alan adının IP adresine nasıl dönüştüğünü gördük. Peki, bu **A**, **AAAA** veya **MX** kayıtlarını kim belirliyor? Tabii ki o alan adını (domain) tescil ettiren kişi veya kurum. Bir alan adını kiraladığınızda (tescil ettirdiğinizde), o alan adına ait tüm DNS kayıtlarını yönetme yetkisi size verilir.

WHOIS Kavramı ve Kayıt Süreci

WHOIS (İngilizce "Who is?" - "Kimdir?" sorusundan gelir), tescil edilmiş bir alan adının kime ait olduğunu, ne zaman alındığını ve ne zaman süresinin dolacağını gösteren devasa bir veri tabanı sorgulama sistemidir.

- **Kayıt Şartı:** Bir alan adını tescil ederken (genelde yıllık ücret ödenir), tescil ettiren kişinin (registrant) **doğru ve güncel iletişim bilgilerini** vermesi yasal bir zorunluluktur.
- **Gizlilik (WHOIS Privacy):** Kişisel bilgilerinin (isim, telefon, adres, e-posta) halka açık olmasını istemeyen kullanıcılar, "Privacy Protection" (Gizlilik Koruması) hizmetlerini kullanabilirler. Bu durumda WHOIS sorgusunda gerçek bilgiler yerine aracı firmanın (örneğin *Domains By Proxy*) bilgileri görünür.

WHOIS Sorgusu ile Hangi Bilgilere Erişilir?

Bir siber güvenlik analizinde (Reconnaissance/Keşif aşaması), WHOIS kayıtları hedef hakkında altın değerinde bilgiler sunabilir:

1. **Registrar (Kayıt Kuruluşu):** Alan adının hangi şirket (GoDaddy, Namecheap vb.) üzerinden alındığı.
2. **Creation/Expiry Date:** Alan adının ilk oluşturulma tarihi ve süresinin ne zaman dolacağı.
3. **Updated Date:** Kayıta yapılan en son değişikliğin tarihi.
4. **Registrant Information:** Alan adını tescil eden kişinin adı, adresi, telefonu ve e-posta adresi.
5. **Admin/Tech Contact:** Yönetimsel ve teknik konularda ulaşılacak kişilerin bilgileri.
6. **Name Servers (NS):** Alan adının hangi DNS sunucularına yönlendirildiği.

Komut Satırı Üzerinden WHOIS Analizi

Linux sistemlerde yüklü gelen `whois` aracı ile bir alan adının tüm künyesini dökümleriz. Aşağıdaki örnekte, gizlilik koruması (privacy protection) aktif olan bir alan adının çıktısını inceliyoruz:

Bash

```
user@TryHackMe$ whois [REDACTED].com
[...]
Domain Name: [REDACTED].COM                # Sorgulanan alan adı
Registry Domain ID: [REDACTED]             # Alan adına ait benzersiz ID
Registrar WHOIS Server: whois.godaddy.com  # Kayıt kuruluşunun WHOIS sunucusu
Registrar URL: https://www.godaddy.com     # Kayıt kuruluşunun web sitesi
Updated Date: 2017-07-05T16:02:43Z        # Son güncelleme zamanı
Creation Date: 1993-04-02T00:00:00Z        # İlk tescil tarihi
Registrar Registration Expiration Date: 2026-10-20T14:56:17Z # Bitiş tarihi
Registrar: GoDaddy.com, LLC                # Alan adının tescil edildiği yer
Registrar IANA ID: 146                     # Kayıt kuruluşunun IANA
```

üzerindeki kimlik numarası

Registrar Abuse Contact Email: abuse@godaddy.com # Suistimal bildirim e-postası

[...]

Registrant Name: Registration Private # İSİM GİZLENMİŞ (Gizlilik Koruması)

Registrant Organization: Domains By Proxy, LLC # GERÇEK KURUM YERİNE ARACI FİRMA

Registrant Street: DomainsByProxy.com # GERÇEK ADRES YERİNE ARACI FİRMA ADRESİ

[...]

Önemli Notlar ve Mantık Çıkarımları:

- **Zaman Analizi:** Creation Date (1993) bilgisinden bu alan adının çok köklü olduğunu, Expiration Date (2026) bilgisinden ise sahibinin bu alan adını uzun vadeli sahiplendiğini anlayabiliriz. Bu, saldırganlar için ortalama (phishing) sitelerini tespit ederken kritik bir veridir (yeni açılmış siteler genelde şüphelidir).
- **Gizlilik Koruması Tespiti:** Eğer Registrant Name kısmında "Registration Private" veya "Privacy Service" gibi ibareler görüyorsanız, hedef kişi gerçek kimliğini gizlemek için ek bir hizmet satın almış demektir. Bu durumda doğrudan hedef kişinin e-postasına ulaşamazsınız ancak Abuse Contact üzerinden kayıt kuruluşu ile iletişime geçebilirsiniz.

HTTP(S): Web Dünyasına Giriş

Tarayıcınızı (Firefox, Chrome vb.) açıp bir web sitesine girdiğinizde aslında en temel iki protokolü kullanırsınız: **HTTP** ve **HTTPS**.

- **HTTP (Hypertext Transfer Protocol):** Hiper Metin Transfer Protokolü. Web tarayıcınız ile web sunucusu arasındaki iletişimin kurallarını belirler.
- **HTTPS (HTTP Secure):** HTTP'nin güvenli versiyonudur. Veriler iletilmeden önce şifrelenir, böylece aradaki bir saldırgan (MITM) verileri okuyamaz.

Her iki protokol de **TCP** (Transmission Control Protocol) üzerinde çalışır, yani veri iletiminin hatasız gerçekleşeceğinden emin olmak için "üçlü el sıkışma" (three-way handshake) yöntemini kullanır.

HTTP Metotları: Sunucuyla Nasıl Konuşuruz?

Tarayıcımız sunucuya sadece "bana bu sayfayı ver" demez; bazen veri gönderir, bazen var olan bir dosyayı silmek ister. Bu amaçla kullanılan en yaygın metotlar şunlardır:

- **GET:** Sunucudan veri çekmek için kullanılır. Bir HTML dosyası, bir resim veya bir script dosyası istenirken bu metot kullanılır.
- **POST:** Sunucuya yeni veri göndermek için kullanılır. Bir kayıt formu doldurduğunuzda veya bir dosya yüklediğinizde veriler bu metotla iletilir.

- **PUT:** Sunucuda yeni bir kaynak oluşturmak veya var olan bir kaynağı tamamen güncellemek (üzerine yazmak) için kullanılır.
- **DELETE:** Sunucudaki belirli bir dosyayı veya kaynağı silmek için kullanılır.

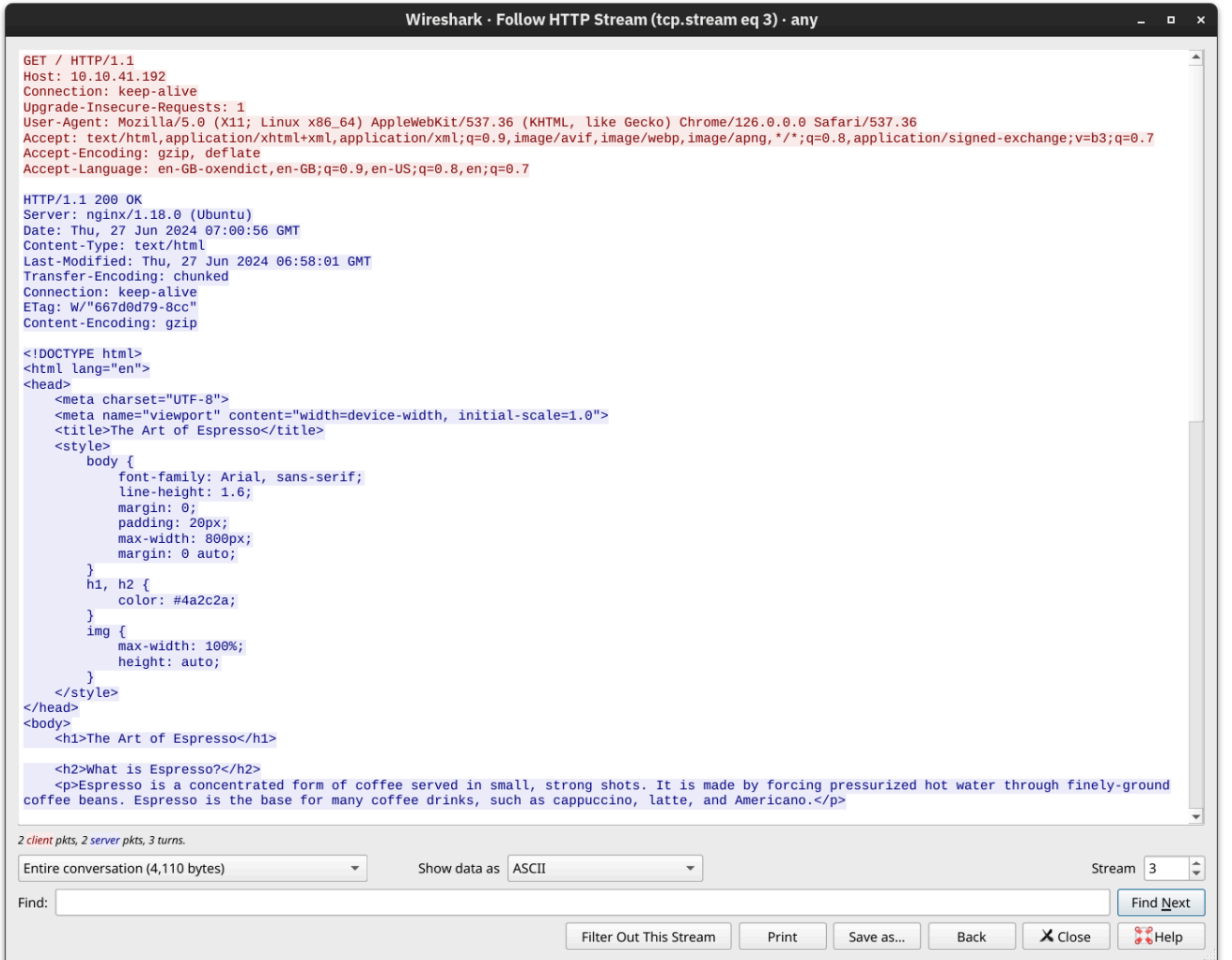
Port Bilgisi

- **HTTP:** Varsayılan olarak **TCP 80** portunu kullanır.
- **HTTPS:** Varsayılan olarak **TCP 443** portunu kullanır.
- **Alternatif Portlar:** Geliştirme ortamlarında veya özel servislerde **8080** (HTTP alternatifi) ve **8443** (HTTPS alternatifi) portlarına da sıkça rastlanır.

Perde Arkası: Wireshark Analizi

Tarayıcı bir sayfayı kusursuz bir şekilde önümüze getirirken arka planda kullanıcıya gösterilmeyen birçok teknik veri (Header/Başlık) alışverişi yapılır. Bir paket analiz aracında (örneğin Wireshark) bu trafiği incelediğimizde şunları görürüz:

- **İstek (Request - Kırmızı):** Tarayıcımızın sunucuya gönderdiği metinler.
- **Yanıt (Response - Mavi):** Sunucunun tarayıcımıza gönderdiği cevap.



Bu trafik içerisinde sayfanın kendisi dışında; **sunucu yazılımının versiyonu**, **sayfanın en son ne zaman güncellendiği**, **çerez (cookie) bilgileri** ve **içerik türü** gibi kritik bilgiler yer

alır. Bir sızma testinde bu "Header" bilgileri, sunucudaki zafiyetleri tespit etmek için ilk bakılan yerdir.

Manuel HTTP: Telnet ile Sunucuyla Konuşmak

HTTP'nin metin tabanlı bir protokol olması, onu bir tarayıcıya ihtiyaç duymadan doğrudan "konuşabilmemizi" sağlar. Bu, özellikle bir web sunucusunda sorun olup olmadığını anlamak (troubleshooting) için mükemmel bir yöntemdir.

Terminal üzerinden bir web sunucusuna bağlanıp manuel bir **GET** isteği gönderelim:

Bash

```
# Web sunucusuna 80 portundan bağlanıyoruz
telnet MACHINE_IP 80

# Bağlantı kurulduktan sonra aşağıdaki satırları manuel yazıp ENTER'a
basıyoruz:
GET / HTTP/1.1
Host: test-sitesi.com
```

Komutun Detayları:

- GET / HTTP/1.1** : Sunucuya "Kök dizindeki (/) dosyayı, HTTP 1.1 protokolünü kullanarak bana getir" diyoruz.
- Host: anything** : Modern web sunucularında (Apache, Nginx vb.) aynı IP üzerinde birden fazla web sitesi barındırılabilirdiği için, sunucuya hangi siteyi istediğimizi belirtmemiz gerekir.
- Dosya Belirtme**: Eğer varsayılan sayfa yerine spesifik bir dosyayı istiyorsak; **GET /dosya.html HTTP/1.1** şeklinde belirtiriz.

Neden Bunu Yapıyoruz? Çünkü tarayıcılar bazen hataları gizleyebilir veya önbellekten (cache) veri getirebilir. `telnet` (veya benzeri `nc` - netcat) kullanarak sunucunun ham cevabını görmek, hatanın sunucu tarafı mı yoksa istemci tarafı mı olduğunu net bir şekilde anlamamızı sağlar.

FTP: Dosya Transfer Protokolü (Transferring Files)

Web sayfalarını görüntülemek için optimize edilen HTTP'nin aksine, **FTP** (File Transfer Protocol), büyük verileri ve dosyaları bir sistemden diğerine aktarmak için tasarlanmıştır. Bu odaklanmış yapısı sayesinde FTP, dosya transferi hızında (tüm koşullar eşit olduğunda) HTTP'ye göre daha yüksek verimlilik sunar.

FTP'nin Çalışma Prensipleri ve Port Yapısı

FTP, ağ dünyasında biraz farklı bir çalışma mekanizmasına sahiptir çünkü **çift kanallı** bir yapı kullanır:

- **Kontrol Kanalı (Port 21):** FTP sunucusu varsayılan olarak **TCP 21** portunu dinler. Komutlar (giriş yapma, dosya listeleme, silme vb.) bu kanal üzerinden gönderilir.
- **Veri Kanalı:** Dosya içeriği veya izin listesi gibi asıl veriler, istemci ve sunucu arasında kurulan **ayrı bir bağlantı** üzerinden akar.
- **Protokol Komutları:** Arka planda istemci ve sunucu şu ham komutlarla konuşur:
 - **USER:** Kullanıcı adını sunucuya iletir.
 - **PASS:** Şifreyi sunucuya iletir.
 - **RETR (Retrieve):** Sunucudan bir dosyayı indirmek (çekmek) için kullanılır.
 - **STOR (Store):** İstemciden sunucuya bir dosya yüklemek için kullanılır.

Uygulamalı FTP Analizi: Anonymous Login

Aşağıdaki senaryoda, bir siber güvenlik uzmanının en sevdiği durumlardan biri olan **Anonymous Login** (Anonim Giriş) zafiyetini ve temel FTP komutlarını inceliyoruz.

Bash

```
user@TryHackMe$ ftp MACHINE_IP
Connected to MACHINE_IP (MACHINE_IP).
220 (vsFTPd 3.0.5)
Name (MACHINE_IP:strategos): anonymous
331 Please specify the password.
Password:
230 Login successful.
```

Adım 1: Bağlantı ve Giriş (Authentication)

- `ftp MACHINE_IP` : İstemci, sunucunun 21. portuna bağlanır.
- **Banner Grabbing:** Sunucu `220 (vsFTPd 3.0.5)` yanıtını döner. Bu çok kritiktir; sunucunun **vsFTPd 3.0.5** versiyonunu kullandığını öğrendik. Bu versiyona özel bir exploit olup olmadığını hemen araştırabiliriz.
- **Anonymous Giriş:** Kullanıcı adı olarak `anonymous` girdik ve şifre kısmını boş bıraktık. `230 Login successful` mesajı, sunucunun dışarıya açık (güvensiz) bir yapılandırmaya sahip olduğunu kanıtlar.

Adım 2: Dosya Keşfi ve Mod Seçimi

Bash

```
ftp> ls
227 Entering Passive Mode (10,10,41,192,134,10).
150 Here comes the directory listing.
```

```
-rw-r--r--    1 0          0          1480 Jun 27 08:03 coffee.txt
-rw-r--r--    1 0          0          14 Jun 27 08:04 flag.txt
ftp> type ascii
200 Switching to ASCII mode.
```

- `ls` : Mevcut dosyaları listeler. Arka planda sunucuya `LIST` komutu gönderilir.
- **Passive Mode**: 227 Entering Passive Mode ifadesi, veri transferi için sunucunun istemciye bir IP ve port açtığını gösterir (Güvenlik duvarlarını aşmak için yaygın kullanılan bir moddur).
- `type ascii` : Transfer modunu ASCII (metin) moduna alır. Eğer bir resim veya program indirseydik `type binary` kullanmalıydık. Yanlış mod seçimi dosyanın bozulmasına neden olabilir.

Adım 3: Dosyayı Ele Geçirme (Exfiltration)

Bash

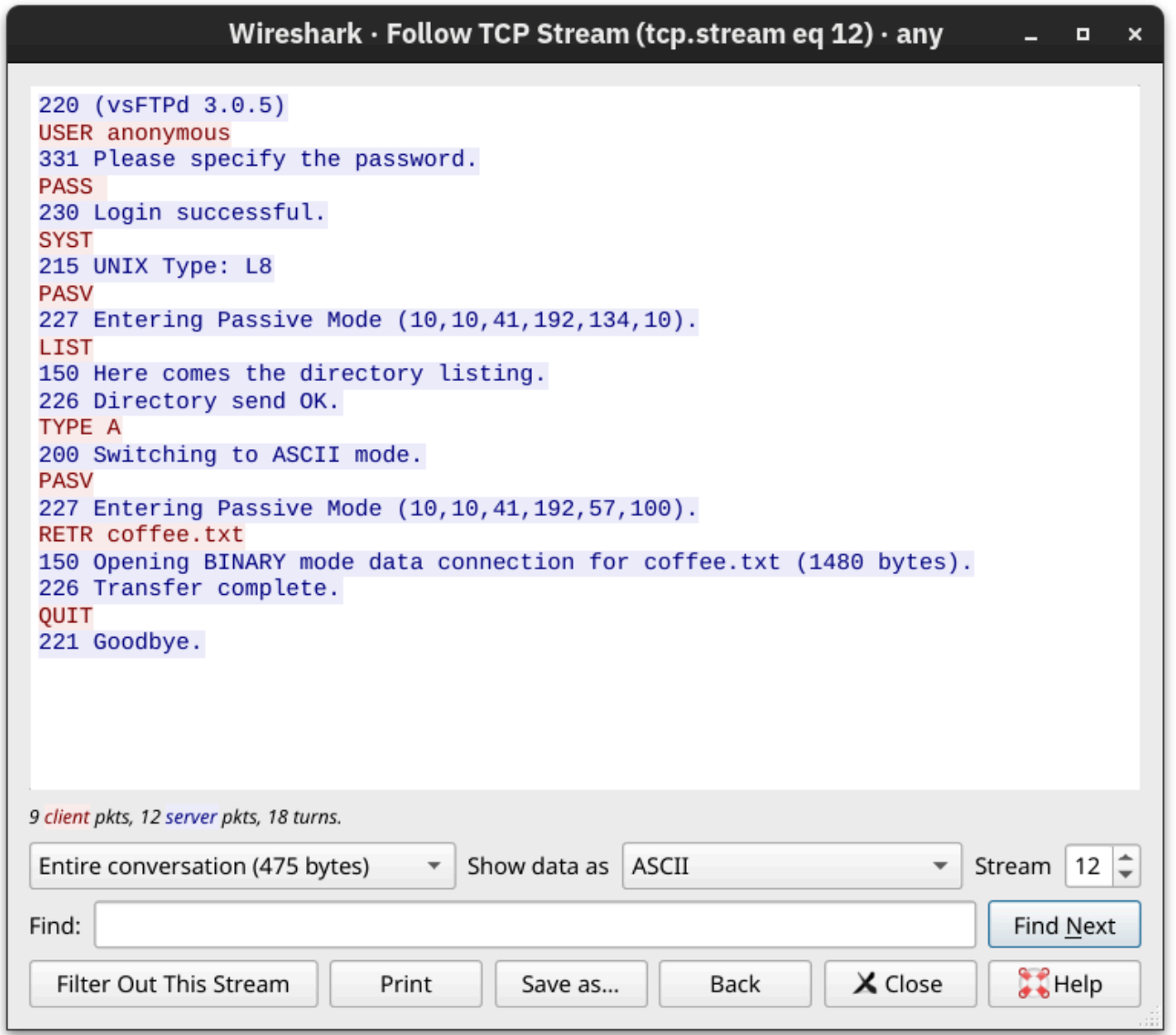
```
ftp> get coffee.txt
local: coffee.txt remote: coffee.txt
150 Opening BINARY mode data connection for coffee.txt (1480 bytes).
226 Transfer complete.
ftp> quit
221 Goodbye.
```

- `get coffee.txt` : Dosyayı hedef sunucudan kendi makinemize indirir. Arka planda `RETR coffee.txt` komutu çalışır.
- `quit` : Bağlantıyı güvenli bir şekilde kapatır.

Wireshark ile Perde Arkası Gözlemi

FTP trafiği **şifrelenmemiştir** (Clear-text). Eğer bu trafiği Wireshark ile izlersek:

1. **Kırmızı Yazılar (İstemci)**: Sizin yazdığınız komutları (USER, PASS, LIST, RETR) görebiliriz.
2. **Mavi Yazılar (Sunucu)**: Sunucunun verdiği yanıt kodlarını (220, 230, 150, 226) görebiliriz.



Kritik Güvenlik Uyarısı: FTP trafiği şifrelenmediği için, ağ üzerindeki herhangi biri (Sniffing yaparak) kullanıcı adınızı ve şifrenizi açık metin olarak görebilir. Bu yüzden modern sistemlerde **SFTP** veya **FTPS** tercih edilir.

SMTP: E-posta Gönderme Protokolü (Sending Email)

Web'de gezinmek (HTTP) veya dosya transfer etmek (FTP) gibi, e-posta göndermenin de kendine has bir protokolü vardır: **SMTP** (Simple Mail Transfer Protocol - Basit Posta Aktarım Protokolü). Bu protokol, bir e-posta istemcisinin (Outlook, Thunderbird vb.) bir posta sunucusuyla veya iki posta sunucusunun birbiriyle nasıl konuşacağını belirler.

SMTP Mantığı: Postane Analogisi

SMTP'nin çalışma mantığını bir postaneye gidip paket göndermeye benzetebiliriz:

1. **Selamlama:** Görevliye "Merhaba" dersiniz (**HELO**).
2. **Gönderici Bilgisi:** Paketi kimin gönderdiğini söylersiniz (**MAIL FROM**).
3. **Alıcı Bilgisi:** Paketin kime gideceğini belirtirsiniz (**RCPT TO**).
4. **İçerik:** Paketi (mesajı) teslim edersiniz (**DATA**).

5. **Bitiş:** İşlemi tamamlayıp postaneden ayrılırsınız (**QUIT**).

Teknik Altyapı ve Komutlar

SMTP, varsayılan olarak **TCP 25** portunu kullanır. İstemci ile sunucu arasındaki diyalogda kullanılan temel komutlar şunlardır:

- **HELO / EHLO:** SMTP oturumunu başlatan selamlama komutudur. **EHLO** (Extended SMTP), modern ve daha fazla özellik destekleyen versiyonudur.
- **MAIL FROM:** E-postayı gönderen adresi tanımlar.
- **RCPT TO:** E-postanın alıcısını tanımlar.
- **DATA:** Bu komuttan sonra yazılacak her şey e-postanın içeriği (gövdesi) olarak kabul edilir.
- **. (Tek bir nokta):** Boş bir satıra konulan tek bir nokta, mesajın bittiğini ve sunucunun artık e-postayı kuyruğa alması gerektiğini ifade eder.
- **QUIT:** Oturumu sonlandırır ve bağlantıyı keser.

Uygulamalı SMTP Analizi: Telnet ile E-posta Gönderme

Tıpkı HTTP ve FTP'de olduğu gibi, SMTP de metin tabanlı bir protokol olduğu için **telnet** kullanarak manuel bir e-posta göndermek mümkündür. Bu, e-posta sunucularının (Mail Transfer Agent - MTA) hatalarını ayıklamak için harika bir yöntemdir.

Bash

```
user@TryHackMe$ telnet MACHINE_IP 25
Connected to MACHINE_IP.
220 example.thm ESMTP Exim 4.95 Ubuntu
```

Analiz: Bağlantı kurulduğunda sunucu bize bir "Banner" döner. Burada sunucunun **Exim 4.95** sürümünü kullandığını ve **Ubuntu** üzerinde çalıştığını net bir şekilde görebiliyoruz. (Siber güvenlikte bu bilgi, o sürüme ait zafiyetleri taramak için kullanılır.)

Adım Adım Oturum Yönetimi:

1. Oturumu Başlatma:

Kod snippet'i

```
HELO client.thm
250 example.thm Hello client.thm [10.11.81.126]
```

250 kodu işlemin başarılı olduğunu gösterir.

2. Adresleri Tanımlama:

Kod snippet'i

```
MAIL FROM: <user@client.thm>
250 OK
RCPT TO: <strategos@server.thm>
250 Accepted
```

3. Mesaj İçeriğini Yazma:

Kod snippet'i

```
DATA
354 Enter message, ending with "." on a line by itself
From: user@client.thm
To: strategos@server.thm
Subject: Telnet email

Hello. I am using telnet to send you an email!
.
```

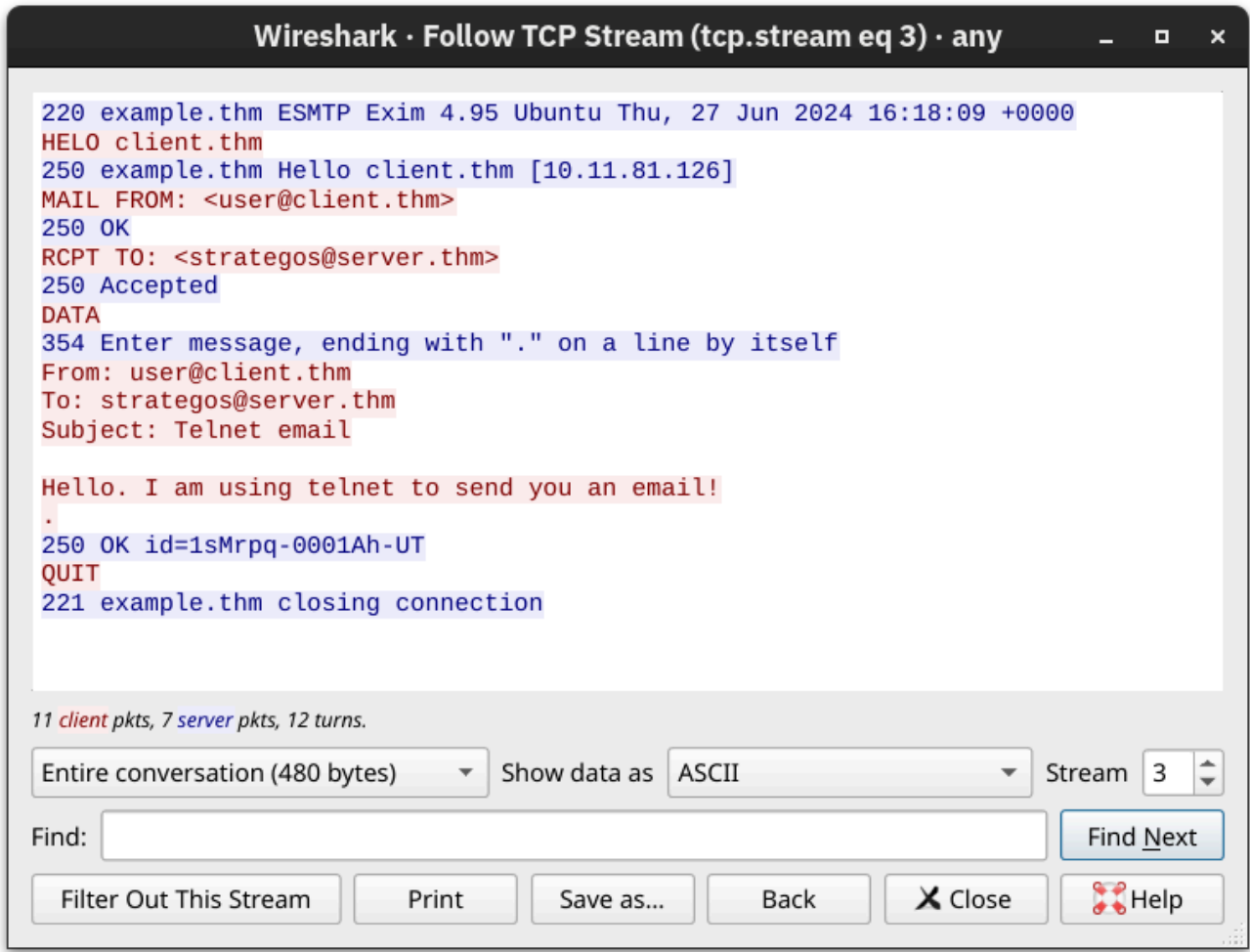
354 yanıtı, sunucunun veriyi almaya hazır olduğunu söyler. Mesaj bittiğinde en alt satıra sadece . koyup ENTER'a basıyoruz.

4. Sonuç ve Çıkış:

Kod snippet'i

```
250 OK id=1sMrpq-0001Ah-UT
QUIT
221 example.thm closing connection
```

Sunucu mesajı kabul ettiğine dair bir ID verir ve bağlantıyı kapatır.



Önemli Güvenlik Notları

- **Clear-text Tehlikesi:** SMTP varsayılan haliyle şifresizdir. Wireshark ile trafiği izleyen biri (Packet Sniffing), e-posta içeriğini, göndereni ve alıcıyı kabak gibi görebilir. Bu yüzden modern sistemlerde **STARTTLS** veya **SMTPS (Port 465/587)** kullanılır.
- **Spam ve Spoofing:** Yukarıdaki örnekte gördüğün gibi, MAIL FROM kısmına istediğimiz adresi yazabiliyoruz. Eğer sunucuda ek güvenlik önlemleri (SPF, DKIM, DMARC) yoksa, başkasının adına e-posta göndermek (spoofing) oldukça kolaydır.

POP3: E-postaları Almak (Receiving Email)

E-posta protokolleri dünyasında, bir e-postayı göndermek işin sadece yarısıdır. Gönderilen o e-postanın sunucudan yerel istemciye (Outlook, Thunderbird veya terminal gibi) indirilmesi gerekir. İşte bu noktada **POP3** (Post Office Protocol version 3) devreye girer.

Mantığı çok basittir: **SMTP** e-postayı postaneye bırakmak gibidir, **POP3** ise postaneye gidip size gelen mektupları kutunuzdan almaktır. POP3, istemcinin sunucuyla iletişim kurup mesajları çekmesine olanak tanır.

Temel POP3 Komutları ve İşlevleri

POP3 ile etkileşime girerken kullanılan komutlar oldukça sınırlı ve anlaşılırdır. Her komut sunucuya ne yapmak istediğimizi söyler:

- **USER <kullanıcı_adı>**: Sunucuya hangi kullanıcı için işlem yapacağımızı belirtir (**Identification**).
- **PASS <şifre>**: Belirtilen kullanıcının parolasını doğrular.
- **STAT**: Mevcut mesaj sayısını ve bu mesajların toplam boyutunu döndürür (**Status**).
- **LIST**: Tüm mesajları numaralandırarak boyutlarıyla birlikte listeler.
- **RETR <mesaj_numarası>**: Belirtilen numaralı mesajın içeriğini getirir (**Retrieve**).
- **DELE <mesaj_numarası>**: Bir mesajı silinmek üzere işaretler (**Delete**).
- **QUIT**: POP3 oturumunu sonlandırır. **Önemli**: Silme işaretli mesajlar ancak bu komutla oturum kapatıldığında sunucudan kalıcı olarak kaldırılır.

POP3 Oturum Analizi (Telnet Üzerinden)

POP3 sunucuları varsayılan olarak **TCP 110** portunu dinler. Şifreleme (SSL/TLS) olmayan bu tür bağlantılarda, tüm trafik "cleartext" yani açık metin halindedir. Aşağıdaki senaryoda, bir terminal üzerinden **telnet** aracıyla POP3 sunucusuna bağlanıp bir mesajı nasıl okuduğumuzu adım adım inceleyelim.

1. Sunucuya Bağlantı Kurma

Bash

```
user@TryHackMe$ telnet MACHINE_IP 110
Trying MACHINE_IP...
Connected to MACHINE_IP.
Escape character is '^]'.
+OK [XCLIENT] Dovecot (Ubuntu) ready.
```

Burada `telnet` ile hedef makinenin **110** portuna bağlandık. Sunucudan gelen `+OK` yanıtı, servisin hazır olduğunu ve bağlantının başarılı olduğunu gösterir.

2. Kimlik Doğrulama (Authentication)

Bağlantı kurulduktan sonra sisteme giriş yapmamız gerekir:

Bash

```
USER strategos
+OK
PASS [PAROLA_BURAYA]
+OK Logged in.
```

`USER` komutuyla hedef kullanıcıyı (`strategos`), `PASS` komutuyla da parolayı gönderdik. Sunucu `+OK Logged in` diyerek girişi onayladı.

Kritik Güvenlik Notu: Bu protokolde şifreleme yoktur. Eğer ağ üzerinde bir saldırgan varsa (örneğin Wireshark ile paket izliyorsa), `PASS` komutunun yanındaki şifreyi hiçbir

zahmete girmeden kabak gibi görebilir.

3. Mesajları Listeleme ve Durum Kontrolü

İçeride kaç e-posta olduğunu ve boyutlarını öğrenelim:

Bash

```
STAT
+OK 3 1264
LIST
+OK 3 messages:
1 407
2 412
3 445
.
```

`STAT` komutu bize 3 mesaj olduğunu ve toplam boyutun 1264 octet (bayt) olduğunu söyledi. `LIST` ise bu 3 mesajı tek tek dökmemizi sağladı. Örneğin 3. mesajın boyutu 445 baytmış.

4. Mesajın İçeriğini Okuma (Retrieval)

Şimdi 3 numaralı mesajı çekelim:

Bash

```
RETR 3
+OK 445 octets
Return-path: <user@client.thm>
Envelope-to: strategos@server.thm
Delivery-date: Thu, 27 Jun 2024 16:19:35 +0000
Received: from [10.11.81.126] (helo=client.thm)
        by example.thm with smtp (Exim 4.95)
        (envelope-from <user@client.thm>)
        id 1sMrpq-0001Ah-UT
        for strategos@server.thm;
        Thu, 27 Jun 2024 16:19:35 +0000
From: user@client.thm
To: strategos@server.thm
Subject: Telnet email

Hello. I am using telnet to send you an email!
.
```

`RETR 3` komutunu verdikten sonra sunucu bize e-postanın **Header** (başlık) bilgilerini ve **Body** (gövde) kısmını döndürdü. Çıktıda gönderen adresini, tarih bilgisini ve nihayetinde "Hello. I am using telnet to send you an email!" şeklindeki asıl mesajı görebiliyoruz. Mesajın sonu bir nokta (.) ile belirtilir.

5. Oturumu Kapatma

Bash

```
QUIT
+OK Logging out.
Connection closed by foreign host.
```

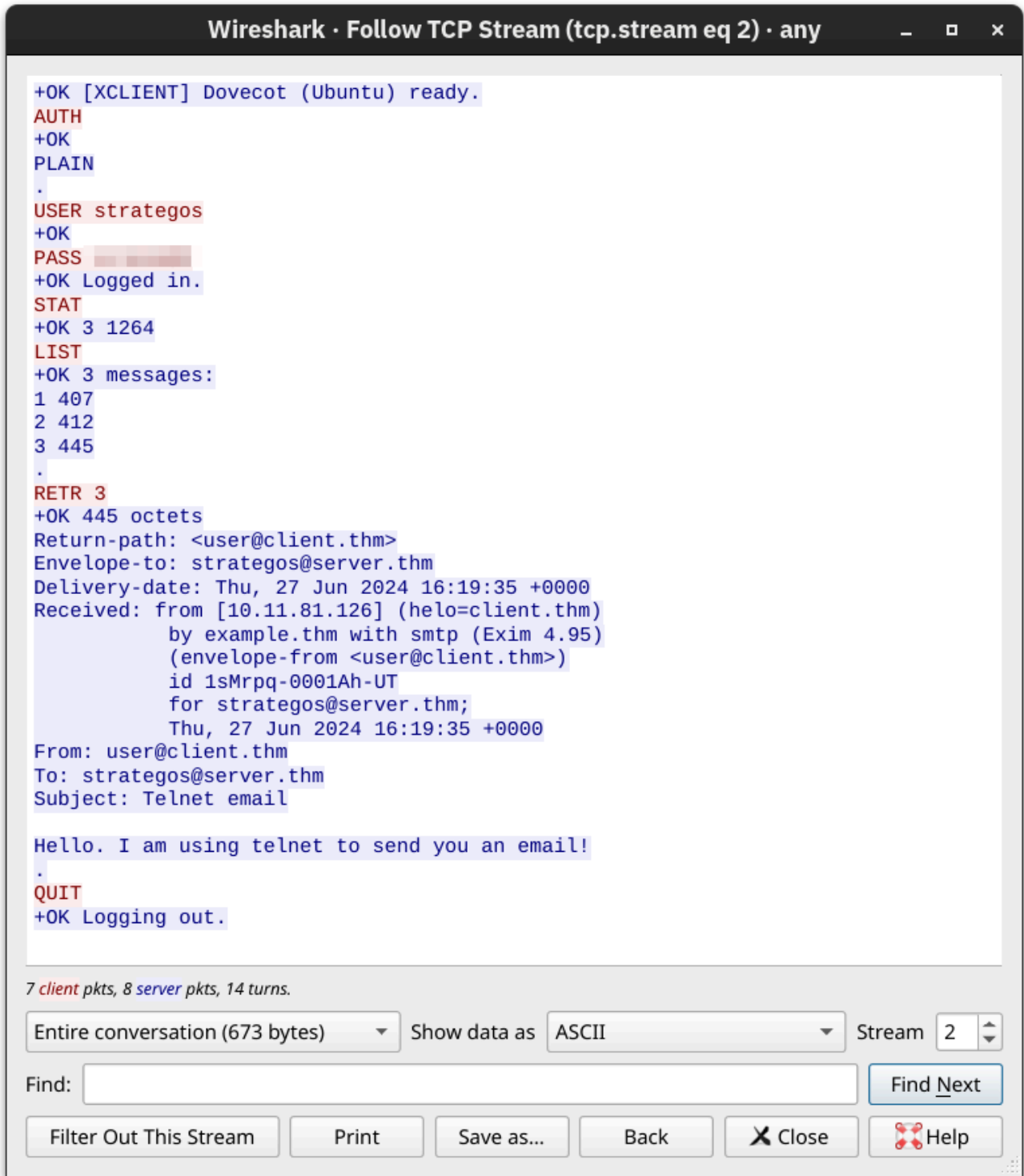
İşimiz bittiğinde `QUIT` diyerek çıkıyoruz. Eğer bu süreçte `DELE` komutuyla bir mesajı silmek üzere işaretleyseydik, o mesajlar tam bu aşamada sunucudan silinecekti.

Özet ve Güvenlik Çıkarımı

POP3 basit ve etkili bir protokol olsa da, **Telnet** veya düz **POP3** üzerinden yapılan işlemler tamamen güvensizdir. Paket yakalama (Packet Capturing) araçlarını kullanan herhangi bir kişi:

1. **Kullanıcı adlarını ve şifreleri** net bir şekilde okuyabilir.
2. **E-posta içeriklerini** ve gönderen bilgilerini manipüle edebilir veya çalabilir.

Modern sistemlerde bu yüzden POP3 yerine genellikle şifreli olan **POP3S (995 portu)** veya daha yetenekli bir protokol olan **IMAP** tercih edilir.



IMAP: E-postaları Senkronize Etmek (Synchronizing Email)

POP3 protokolü tek bir cihazdan (örneğin sadece masaüstü bilgisayarınızdan) e-postaları kontrol etmek için yeterlidir. Ancak günümüzde e-postalarımızı hem telefonumuzdan, hem tabletimizden hem de iş bilgisayarımızdan kontrol ediyoruz. Eğer POP3 kullansaydık, e-posta bir cihaza indiği anda sunucudan silineceği için diğer cihazlarda göremezdik.

İşte bu noktada **IMAP** (Internet Message Access Protocol) devreye girer. IMAP'in temel felsefesi **senkronizasyondur**. Mesajlar sunucuda tutulur; bir cihazda e-postayı

okuduğunuzda, sildiğinizde veya başka bir klasöre taşıdığınızda bu değişiklik tüm cihazlarda anında güncellenir.

POP3 vs IMAP Farkı (Kritik Özet):

- **POP3:** İndir ve sil mantığıyla çalışır. Sunucu depolama alanını az kullanır ama çoklu cihaz desteği zayıftır.
- **IMAP:** Sunucuda tut ve senkronize et mantığıyla çalışır. Sunucuda daha fazla yer kaplar ancak modern dünya için çok daha elverişlidir.

IMAP Komutları ve Sözdizimi (Syntax)

IMAP komutları POP3'e göre biraz daha karmaşıktır. En önemli fark, her komutun başına bir **etiket (Tag)** (A, B, C veya 001, 002 gibi) eklememiz gerekmesidir. Sunucu cevabını dönerken bu etiketi kullanarak hangi komuta cevap verdiğini belirtir.

- **LOGIN <kullanıcı_adi> <şifre>:** Kullanıcı kimliğini doğrular.
- **SELECT <klasör>:** İşlem yapılacak posta kutusunu (genellikle `inbox`) seçer.
- **FETCH <mesaj_no> <veriöğesi>:** Belirli bir mesajın detaylarını çeker. Örneğin `FETCH 3 body[]` komutu, 3 numaralı mesajın hem başlıklarını hem de gövdesini tam olarak getirir.
- **MOVE <mesaj_aralığı> <klasör>:** Mesajları bir klasörden diğerine taşır.
- **COPY <mesaj_aralığı> <klasör>:** Mesajları başka bir klasöre kopyalar.
- **LOGOUT:** Oturumu güvenli bir şekilde kapatır.

IMAP Oturum Analizi (Telnet Üzerinden)

IMAP sunucuları varsayılan olarak **TCP 143** portunu kullanır. Şimdi **telnet** ile bir IMAP oturumu başlatalım ve manuel olarak e-posta çekmeyi deneyelim.

1. Sunucuya Bağlantı

Bash

```
user@TryHackMe$ telnet 10.10.41.192 143
Trying 10.10.41.192...
Connected to 10.10.41.192.
* OK [CAPABILITY IMAP4rev1 ...] Dovecot ready.
```

Sunucu bağlantıyı kabul etti ve desteklediği özellikleri (CAPABILITY) bize listeledi.

2. Giriş Yapma (Login)

Bash

```
A LOGIN strategos [PAROLA]
A OK [...] Logged in
```

Komutun başına **A** etiketini koyduk. Sunucu girişin başarılı olduğunu **A OK** diyerek onayladı.

3. Gelen Kutusu Seçimi (Select Inbox)

Mesajları görmenden önce hangi klasörle çalışacağımızı seçmeliyiz:

Bash

```
B SELECT inbox
* 4 EXISTS
* 0 RECENT
* OK [UNSEEN 2] First unseen.
B OK [READ-WRITE] Select completed.
```

- **4 EXISTS:** Gelen kutusunda toplam 4 mesaj olduğunu söylüyor.
- **UNSEEN 2:** Henüz okunmamış mesajların olduğunu belirtiyor.
- **READ-WRITE:** Klasörü hem okuma hem de üzerinde değişiklik yapma (silme, taşıma vb.) yetkisiyle açtığımızı gösterir.

4. Mesajı Çekme (Fetch)

Daha önce SMTP ile gönderdiğimiz 3 numaralı mesajı okuyalım:

Bash

```
C FETCH 3 body[]
* 3 FETCH (BODY[] {445}
Return-path: <user@client.thm>
From: user@client.thm
Subject: Telnet email

Hello. I am using telnet to send you an email!
)
C OK Fetch completed.
```

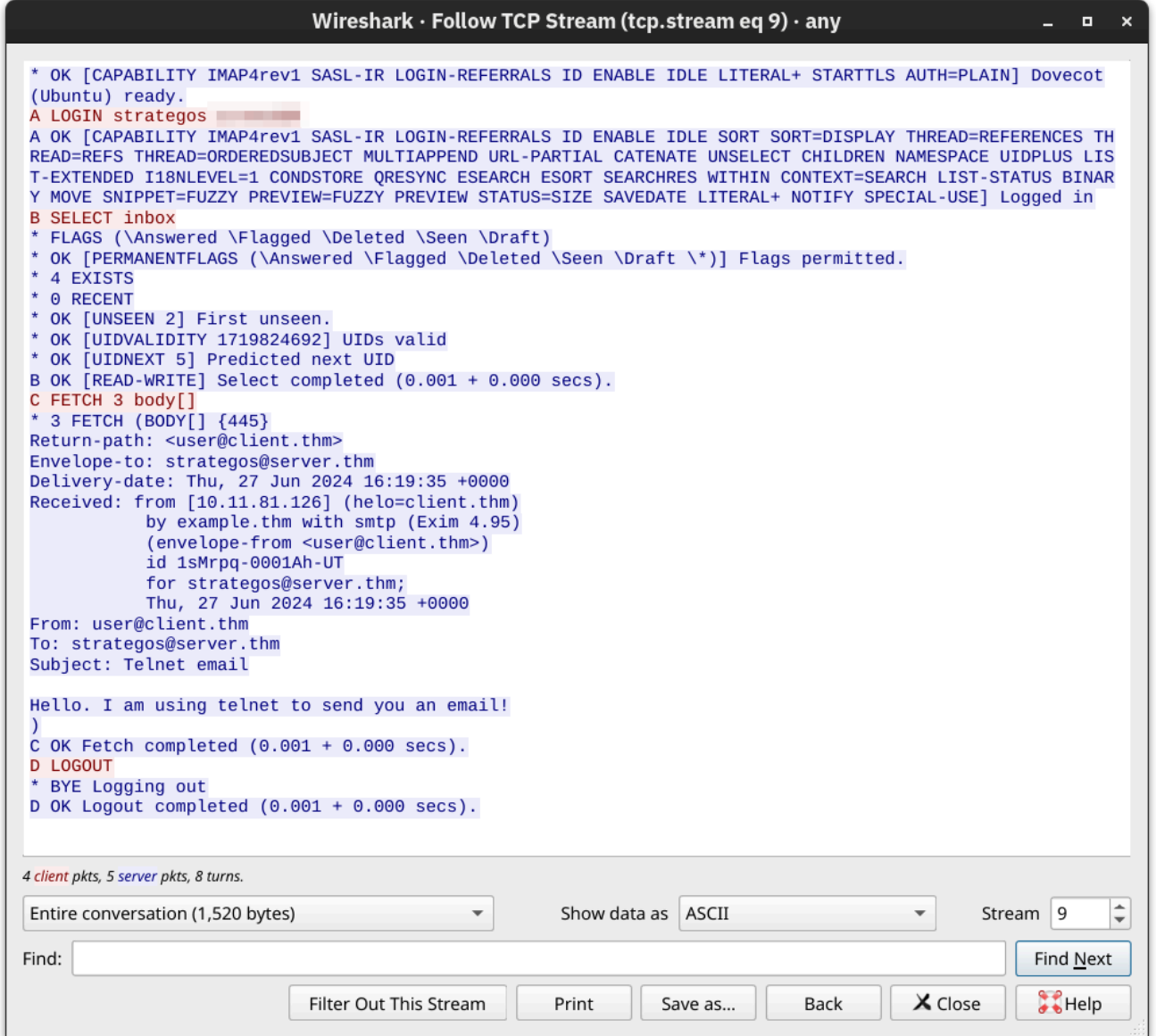
`FETCH 3 body[]` komutuyla 3. mesajın tüm içeriğini istedik. Sunucu bize e-posta başlıklarını (Header) ve mesaj gövdesini (Body) getirdi. Mesajın sonundaki `)` işareti verinin bittiğini gösterir.

5. Çıkış Yapma

Bash

D LOGOUT
* BYE Logging out
D OK Logout completed.

D etiketiyle oturumu sonlandırdık.



```
* OK [CAPABILITY IMAP4rev1 SASL-IR LOGIN-REFERRALS ID ENABLE IDLE LITERAL+ STARTTLS AUTH=PLAIN] Dovecot (Ubuntu) ready.  
A LOGIN strategos  
A OK [CAPABILITY IMAP4rev1 SASL-IR LOGIN-REFERRALS ID ENABLE IDLE SORT SORT=DISPLAY THREAD=REFERENCES TH  
READ=REFS THREAD=ORDEREDSUBJECT MULTIAPPEND URL-PARTIAL CATENATE UNSELECT CHILDREN NAMESPACE UIDPLUS LIS  
T-EXTENDED I18NLEVEL=1 CONDSTORE QRESYNC ESEARCH ESORT SEARCHRES WITHIN CONTEXT=SEARCH LIST-STATUS BINAR  
Y MOVE SNIPPET=FUZZY PREVIEW=FUZZY PREVIEW STATUS=SIZE SAVEDATE LITERAL+ NOTIFY SPECIAL-USE] Logged in  
B SELECT inbox  
* FLAGS (\Answered \Flagged \Deleted \Seen \Draft)  
* OK [PERMANENTFLAGS (\Answered \Flagged \Deleted \Seen \Draft \*)] Flags permitted.  
* 4 EXISTS  
* 0 RECENT  
* OK [UNSEEN 2] First unseen.  
* OK [UIDVALIDITY 1719824692] UIDs valid  
* OK [UIDNEXT 5] Predicted next UID  
B OK [READ-WRITE] Select completed (0.001 + 0.000 secs).  
C FETCH 3 body[]  
* 3 FETCH (BODY[] {445}  
Return-path: <user@client.thm>  
Envelope-to: strategos@server.thm  
Delivery-date: Thu, 27 Jun 2024 16:19:35 +0000  
Received: from [10.11.81.126] (helo=client.thm)  
by example.thm with smtp (Exim 4.95)  
(envelope-from <user@client.thm>  
id 1sMrpq-0001Ah-UT  
for strategos@server.thm;  
Thu, 27 Jun 2024 16:19:35 +0000  
From: user@client.thm  
To: strategos@server.thm  
Subject: Telnet email  
  
Hello. I am using telnet to send you an email!  
)  
C OK Fetch completed (0.001 + 0.000 secs).  
D LOGOUT  
* BYE Logging out  
D OK Logout completed (0.001 + 0.000 secs).
```

Güvenlik Notu ve Wireshark Analizi

Tıpkı POP3 gibi, standart IMAP (Port 143) de verileri **şifrelemeden (cleartext)** gönderir. Wireshark ile ağ trafiği izlendiğinde:

- LOGIN komutuyla gönderilen **parolalar** açıkça okunabilir.
- FETCH ile çekilen tüm **e-posta içerikleri** saldırganlar tarafından ele geçirilebilir.

Bu riskleri önlemek için günümüzde **IMAPS (Port 993)** kullanılarak tüm trafik SSL/TLS ile şifrelenir.

Özet ve Protokol Port Bilgisi (Conclusion)

Bu çalışmamızda, ağ dünyasının temel taşlarını oluşturan kritik protokolleri derinlemesine inceledik. Daha önce gördüğümüz **TELNET** protokolüne ek olarak; alan adlarının nasıl çözümlendiğini (**DNS**), web sayfalarının nasıl sunulduğunu (**HTTP/HTTPS**), dosyaların nasıl transfer edildiğini (**FTP**) ve e-postaların uçtan uca nasıl iletildiğini (**SMTP**, **POP3**, **IMAP**) teknik detaylarıyla analiz ettik.

Bu notların asıl amacı, günlük hayatta kullandığımız grafik arayüzlerin (tarayıcılar, e-posta istemcileri vb.) arka planında dönen ham etkileşimi ve mantık zincirini anlamaktır. Bir siber güvenlik uzmanı adayı olarak, arayüzlerin arkasındaki bu "saf" protokol dilini bilmek, zafiyetleri tespit etmenin ve sömürmenin ilk kuralıdır.

Protokol ve Port Özet Tablosu

Aşağıdaki tablo, şu ana kadar işlediğimiz tüm protokollerin kullandığı taşıma katmanı protokollerini ve varsayılan port numaralarını göstermektedir. Bu tablo, **enumeration** (numaralandırma/bilgi toplama) aşamasında ezbere bilinmesi gereken hayati bilgiler içerir:

Protokol	Taşıma Protokolü (Transport)	Varsayılan Port (Port Number)
TELNET	TCP	23
DNS	UDP veya TCP	53
HTTP	TCP	80
HTTPS	TCP	443
FTP	TCP	21
SMTP	TCP	25
POP3	TCP	110
IMAP	TCP	143

Kritik Çıkarımlar

- DNS:** Hem UDP (genellikle hızlı sorgular için) hem de TCP (büyük veri transferleri veya zone transfer için) kullanabilen nadir protokollerdendir.
- Güvenlik (Encryption):** Bu tabloda gördüğümüz **HTTPS** dışındaki protokollerin çoğu (varsayılan halleriyle) veriyi şifrelemeden gönderir. Bu durum, ağ üzerinde "Man-in-the-Middle" (Ortadaki Adam) saldırılarına kapı aralar.
- Portlar:** Tarama yaparken (örneğin `nmap` ile) bu portların açık olması, doğrudan ilgili servisin içeride çalıştığına dair en güçlü kanıttır.